

ZEROTRUST - ONE

Enterprise Technical Architecture, Heuristic Matrix & API Specification

Comprehensive Engineering Reference Document for SOC Operations & Platform Engineers

ARCH: ZERO-TRUST PIPELINE

CONSENSUS MATRIX v3.2

LEVEL: DEEP-DIVE SPEC

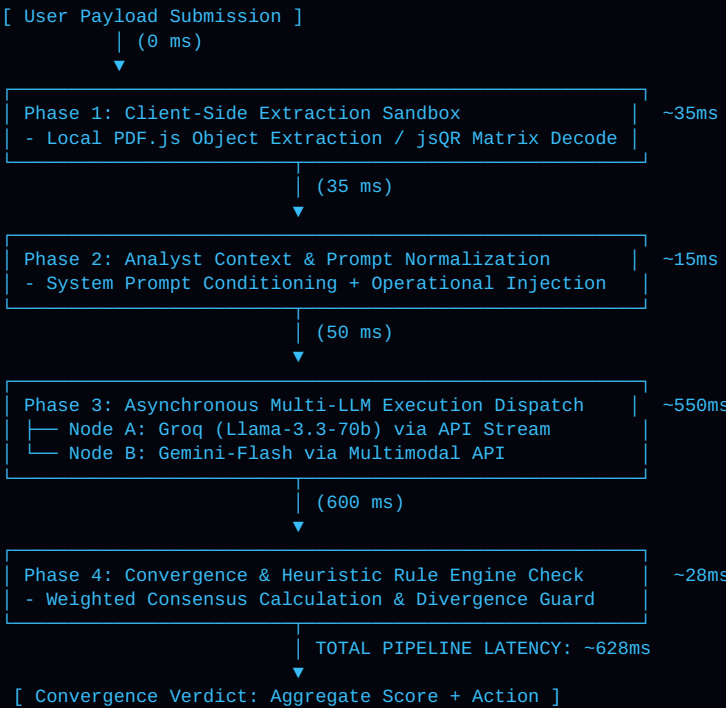
LATENCY TARGET: < 750ms

1. ARCHITECTURAL PRINCIPLES & ISOLATION MODEL

ZeroTrust-One implements an air-gapped threat analysis architecture designed to isolate untrusted ingress streams prior to internal system exposure. Operating on the principle of **Strict Non-Execution during Inspection**, raw payloads (raw MIME header blocks, document streams, 2D barcode images, binary dumps) are sanitized, decoded, and analyzed inside client-side isolated memory buffers before dispatching normalized structural tokens to the inference engine.

The core engine pairs deterministic pattern matching with an asynchronous **Dual-LLM AI Consensus Engine (v3.2)** running **Groq Llama-3.3-70b** and **Gemini-Flash** in parallel, achieving zero-trust safety and real-time execution response.

2. EXECUTION SEQUENCE & LATENCY BUDGET ALLOCATION



3. MATHEMATICAL MODEL FOR AI CONSENSUS SCORING

Weighted Consensus & Divergence Penalty Formula

Let $S_{\text{Groq}} \in [0, 100]$ and $S_{\text{Gemini}} \in [0, 100]$ be the individual risk scores returned by the Groq and Gemini engine nodes, respectively. Let $R_{\text{heur}} \in [0, 30]$ represent additional risk points assigned by deterministic Rule Engine v1.

The raw weighted composite risk score S_{raw} is calculated as:

$$S_{\text{raw}} = (0.45 * S_{\text{Groq}}) + (0.55 * S_{\text{Gemini}}) + R_{\text{heur}}$$

To guard against model hallucination or single-node evasion attacks, a **Divergence Penalty Flag** (D_{flag}) is evaluated:

```
If |S_Groq - S_Gemini| > 40:  
  D_flag = True  
  S_final = max(S_raw, 55) # Forces verdict to QUARANTINE & MANUAL REVIEW minimum
```

4. INSPECTION ENGINES & DEEP TECHNICAL PARSERS

A. MIME & Email Header Engine

- **SPF Protocol Check:** Validates origin IP against published TXT SPF records (v=spf1).
- **DKIM RSA Signature:** Validates body hash (bh=) and canonicalized headers against public DNS keys.
- **DMARC Alignment:** Confirms strict or relaxed domain alignment between RFC5322 From and envelope senders.
- **Routing Chain Telemetry:** Detects unauthorized relay hops and missing message IDs.

B. PDF & Visual Sandbox Parsers

- **PDF Object Traversal:** Scans trailer dictionaries for /JS, /JavaScript, /Launch, /AA (Auto Action), and /OpenAction.
- **Zero-Connection Quishing Decoder:** Decodes QR luminance matrices in memory using jsQR, isolating target URIs without triggering tracking pixels.
- **Entropy Analysis:** Calculates Shannon entropy (\$H \ge 7.2\$) on binary files to detect packed payloads.

5. SPECIALIZED PAYLOAD MATRIX

PAYLOAD TYPE	PARSER ENGINE	DEEP SECURITY INSPECTION SCOPE
RAW_EMAIL_HEADERS_AND_BODY	Strict Security Zero-Trust	MIME parsing, SPF/DKIM/DMARC validation, reply-to mismatch detection, domain typosquatting, credential harvesting syntax.
HTTP_URL_STRING	URI Inspector Engine	IDN homograph spoofing, open redirect chain expansion, suspicious query parameter entropy, domain age/reputation lookup.
UNSTRUCTURED_TEXT_PAYLOAD	NLP Heuristic Scanner	Prompt injection / jailbreak payload detection, social engineering urgency patterns, PII leakage, credential harvesting keywords.
QR_CODE_IMAGE_SCAN	jsQR Visual Matrix	Client-side 2D barcode matrix decoding, URI extraction, protection against quishing (QR phishing) and obfuscated redirections.
PDF_DOCUMENT_PAYLOAD	PDF.js Extractor	Structural object graph parsing, detection of embedded executable streams, form auto-actions, launch triggers, text layer extraction.
BINARY_FILE_ARTIFACT	Static Artifact Analyzer	PE/ELF header validation, section entropy analysis, anomalous imports detection, shellcode heuristics, compiler footprinting.

6. ANALYST CONTEXT INJECTION ENGINE

Context Enrichment Mechanics: Conventional AI scanning engines evaluate input data strictly in isolation, leading to high false-positive rates when processing legitimate administrative scripts or internal batch emails. ZeroTrust-One allows SOC analysts to supply operational context (e.g., *"Reported by finance department; expected monthly invoice PDF"*). This context is injected directly into the LLM system prompt:

```
SYSTEM_PROMPT: "Evaluate payload against provided analyst context. Flag any mismatch between claimed intent ('expected monthly invoice') and actual payload features (e.g., presence of executable JavaScript stream or credential harvesting form)."
```

7. THRESHOLD SPECTRUM & ENFORCEMENT POLICY

SCORE RANGE	RISK LEVEL	ENFORCEMENT ACTION	SYSTEM BEHAVIOR & SOC ROUTING
0 - 30	LOW / SAFE	No Threat Detected	Payload passed all heuristics and AI consensus checks. Automatic egress permission granted.
31 - 70	MEDIUM / SUSPICIOUS	Quarantine & Review	Anomalous signature or model disagreement detected. Payload isolated; tier-2 SOC analyst ticket dispatched.
71 - 100	HIGH / CRITICAL	Block & Terminate Session	Confirmed malicious vector (e.g., weaponized PDF stream or credential phishing URI). Immediate session drop and IP rate-limiting.

